

Actividad 01: Análisis y Planificación del Pentest

Evaluación de Seguridad Integral — Caso: Aurora Market (Versión Corregida y Ampliada)

Estudiante: Yesica Perez

Cohorte: 1ª Generación

Versión: 2.0 (Entrega Corregida)

Fecha: Septiembre, 2026

1. OBJETIVOS DEL PENTEST (ENFOQUE ESTRATÉGICO Y DE NEGOCIO)

Aurora Market ha experimentado una acelerada transformación digital al migrar desde ventas informales en redes sociales hacia una plataforma de comercio electrónico de alta demanda. No obstante, se detectó un incidente de seguridad crítico: **un comprador logró visualizar el historial y detalle de pedidos pertenecientes a otro usuario**. Este hecho enciende alarmas operativas y reputacionales inmediatas. No se trata simplemente de un bug visual, sino de un síntoma de fallos estructurales en la capa de autorización y control de acceso.

¿Por qué es imperativo realizar este Pentest para la Organización?

Si Aurora Market opera sin diagnosticar ni corregir esta brecha de raíz, enfrenta la posibilidad inminente de una filtración masiva de bases de datos que contengan nombres completos, números de teléfono, direcciones particulares y registros transaccionales de miles de clientes. Una brecha pública acarrearía demandas civiles, pérdida irreversible de confianza de los consumidores y severas sanciones por incumplimiento de normativas de protección de datos personales. Esta evaluación técnica preventiva le brinda a la dirección visibilidad certera del nivel de exposición de sus activos y una hoja de ruta priorizada para subsanar fallas antes de que sean explotadas por ciberdelincuentes.

Los 3 objetivos técnicos y estratégicos fundamentales son:

1. **Determinar la causa raíz de la fuga de información entre sesiones:** Evaluar si el sistema adolece de problemas de *Insecure Direct Object References* (IDOR / BOLA), donde la aplicación confía ciegamente en parámetros numéricos o identificadores modificables desde la URL o el cuerpo de la petición HTTP, permitiendo consultar datos ajenos sin comprobar la titularidad de la sesión activa.
2. **Validar la correcta segregación de privilegios (Horizontales y Verticales):** Comprobar minuciosamente que los roles asignados a clientes regulares mantengan un aislamiento total respecto a otros usuarios, y verificar que no existan vectores que permitan a un cliente escalar privilegios hacia funciones administrativas o paneles del personal interno (empleados de almacén, finanzas o gestión de productos).
3. **Medir la postura defensiva global y generar un plan de remediación aplicable:** Analizar la configuración de servidores y servicios asociados para identificar vulnerabilidades conexas y dotar al equipo de ingeniería de software de recomendaciones accionables y código seguro para mitigar cada debilidad identificada.

2. ALCANCE DE LA EVALUACIÓN

DENTRO DEL ALCANCE (IN-SCOPE)

- **Portal Web de Clientes:** Módulos de registro, autenticación (login/logout), recuperación de credenciales, catálogo de productos, carrito de compras, pasarela interna y consulta histórica de pedidos (`/mis-pedidos` , `/pedido?id=`).
- **Panel Administrativo y de Empleados:** Interfaces de gestión interna empleadas por el personal de Aurora Market para inventario, asignación de envíos y administración de usuarios.
- **Lógica de Aplicación y APIs HTTP/REST:** Endpoints de backend, intercambio de parámetros, persistencia de estado, cookies y validación de tokens de sesión.

FUERA DEL ALCANCE (OUT-OF-SCOPE)

- **Ataques de Denegación de Servicio (DoS/DDoS):** Queda terminantemente prohibido inundar canales con tráfico volumétrico o ejecutar pruebas de estrés que comprometan la operatividad del sitio web.
- **Ingeniería Social y Phishing:** Prohibido enviar correos falsos, spear phishing o suplantación dirigida al personal administrativo, directivos o clientes de la plataforma.
- **Servicios Externos y Pasarelas de Terceros:** Servidores bancarios de pasarelas de pago externas, APIs de logística de envíos de terceros y redes físicas de los proveedores de nube.

3. AUTORIZACIÓN, CONDICIONES Y PROPUESTA DE HORARIOS

Permisos y Condiciones Acordadas:

Ninguna acción de sondeo activo se iniciará sin contar con el **Documento Formal de Autorización (Rules of Engagement / RoE)** firmado por la dirección legal y técnica de Aurora Market. Las condiciones contemplan la entrega de credenciales de prueba controladas: **dos cuentas de cliente regular (Usuario A y Usuario B)** con órdenes previamente cargadas para auditar la segregación horizontal, y **una cuenta con perfil operativo/empleado** para verificar la segregación vertical. Se pacta el compromiso explícito de no alterar, descargar masivamente ni destruir registros de clientes reales.

Ventana de Horarios Propuesta y Justificación Operativa:

Horario acordado: Lunes a viernes de 00:00 a 05:00 hrs (Horario Nocturno / Madrugada).

Justificación: Aurora Market opera un modelo transaccional donde los picos de visitas, cotizaciones y compras se concentran durante el día y la tarde. Lanzar escaneos activos, pruebas de fuerza bruta o interceptaciones masivas en horario comercial podría generar latencia anormal en las bases de datos, bloquear pagos de clientes legítimos o degradar la experiencia de compra. La madrugada representa la curva de menor afluencia, aislando el impacto sobre la facturación del negocio. Adicionalmente, se establecerá un canal de mensajería directa (War Room) con el personal de infraestructura de guardia ante cualquier anomalía o reinicio preventivo requerido.

4. TIPO DE PENTEST Y METODOLOGÍA SELECCIONADA

Modalidad: Gray-Box (Caja Gris)

Justificación: Aurora Market provee conocimiento de la arquitectura funcional general (existencia de perfiles de clientes y empleados, endpoints principales) y credenciales de acceso para testing, pero no entrega código fuente ni accesos root a los servidores.

Esta modalidad simula de forma exacta el perfil de un atacante oportunista o un cliente malintencionado que, contando con una cuenta válida en el portal, manipula peticiones para saltarse controles de seguridad. Es el enfoque más eficiente en costo-beneficio para auditar problemas de lógica y autorización web en tiempos acotados.

Metodología: OWASP WSTG v4.2

Justificación: La *Web Security Testing Guide (WSTG)* de OWASP es el estándar industrial por excelencia para auditar aplicaciones web e interfaces transaccionales de comercio electrónico.

Cuenta con categorías exhaustivas y metodológicamente estructuradas que apuntan de forma directa al problema de Aurora Market: pruebas específicas para *Authorization Testing* (WSTG-ATHZ-02: Bypass de autorización e IDOR), validación de gestión de sesiones (WSTG-SESS) y evaluación de controles de entrada (WSTG-INPV), asegurando un análisis riguroso y repetible.

5. RECOPIACIÓN DE INFORMACIÓN Y PRÁCTICA CON HERRAMIENTAS

La recopilación de información integrará **fuentes abiertas (OSINT / reconocimiento pasivo)** y **fuentes internas / reconocimiento activo**:

- **Fuentes Abiertas (OSINT - Pasivo):** Se aplicarán técnicas que no interactúan directamente con los servidores productivos para evitar alertas tempranas. Se emplearán registros DNS (`dig` , `nslookup`), consultas Whois, inspección de registros de certificados SSL/TLS (`crt.sh`) y *Google Dorking* avanzado (`site:auroramarket.com filetype:pdf o inurl:admin`). *Objetivo:* Descubrir subdominios olvidados, ambientes de prueba expuestos (ej. `dev.auroramarket.com` , `test-api.auroramarket.com`) y posibles fugas de información institucional o correos corporativos.
- **Fuentes Internas / Reconocimiento Activo:** Se interactuará con el servidor analizando las respuestas HTTP, el archivo `robots.txt` , `sitemap.xml` y utilizando extensiones de fingerprinting como Wappalyzer para catalogar el servidor web (Nginx/Apache), lenguaje de backend (PHP, NodeJS, Python) y librerías frontend (React, Vue, jQuery).

Herramienta	Práctica y Procedimiento a Realizar	Propósito y Qué se Espera Obtener
Nmap Escáner de Red	Lanzar escaneo perimetral controlado sobre la dirección IP pública del servicio mediante el comando: <code>nmap -sV -sC -p 80,443,8080,8443,21,22 -T3 target</code>	Mapear los puertos abiertos y obtener el fingerprint de los servicios en escucha. Se espera confirmar si únicamente los puertos HTTP/HTTPS están expuestos o si existen paneles de bases de datos o servicios de administración (SSH, FTP) accesibles públicamente con configuraciones por defecto.
OWASP ZAP Proxy y Escáner Web	Configurar ZAP como proxy intermediario para auditar la navegación del usuario. Ejecutar un <i>Spidering</i> (rastreo de enlaces) y un escaneo pasivo de directivas de seguridad web en paralelo al flujo de navegación.	Descubrir directorios no enlazados, endpoints ocultos de APIs, falta de cabeceras de endurecimiento (<code>CSP</code> , <code>HSTS</code> , <code>X-Frame-Options</code>), ausencia de atributos de seguridad en cookies (<code>HttpOnly</code> , <code>Secure</code> , <code>SameSite</code>) y detectar formularios expuestos a inyecciones.
Burp Suite Proxy Interceptor	Interceptar manualmente peticiones HTTP transaccionales hacia el servidor. Emplear la herramienta <i>Repeater</i> para aislar solicitudes de consulta de órdenes (<code>GET /api/pedidos?id=101</code>) y reenviarlas modificando parámetros identificadores.	Manipular peticiones con la sesión activa del Usuario A enviando el identificador del pedido del Usuario B. El objetivo es comprobar con evidencia irrefutable si el servidor valida la pertenencia de los datos antes de responder, confirmando técnicamente la existencia de fallos IDOR.

6. LAS 5 FASES DEL PENTEST APLICADAS AL ESCENARIO DE AURORA MARKET

Siguiendo las mejores prácticas profesionales, la evaluación se articulará en 5 fases secuenciales, justificando qué acciones se toman en cada una y por qué son determinantes para resolver el problema de Aurora Market:

Fase 1: Reconocimiento (Footprinting & Discovery)

Qué haríamos y cómo: Realizaremos una identificación pasiva y activa de activos. Se escaneará la infraestructura perimetral con **Nmap** para catalogar puertos abiertos y versiones de servicios. Simultáneamente, emplearemos el crawler de **OWASP ZAP** junto con una navegación funcional exhaustiva por la tienda virtual, catalogando cada URL, parámetro de consulta, formulario de entrada y ruta del catálogo.

Por qué y qué esperamos: Permite construir un mapa arquitectónico de la plataforma sin dejar puntos ciegos. Buscamos identificar todos los posibles puntos de entrada (rutas de autenticación, consulta de comprobantes, rutas de administración como `/admin` o `/panel-empleado`) para dirigir los esfuerzos a los puntos verdaderamente críticos.

Fase 2: Análisis de Vulnerabilidades (Vulnerability Assessment)

Qué haríamos y cómo: Tomando el mapa de endpoints obtenido en el reconocimiento, analizaremos el flujo de las peticiones mediante **OWASP ZAP** y revisión manual asistida. Evaluaremos cómo se gestionan las sesiones de usuario, el ciclo de vida de los tokens de autenticación y la estructura de los identificadores en las URLs (por ejemplo, si los pedidos usan números enteros secuenciales como `id=1045` o UUIDs robustos).

Por qué y qué esperamos: El análisis busca detectar anomalías lógicas y debilidades de configuración sin intentar explotarlas aún. Buscamos verificar si existen solicitudes donde el cliente solicita datos personales mediante parámetros manipulables, lo que señalaría una alta probabilidad de ausencia de controles de acceso en el backend.

Fase 3: Explotación Controlada (Exploitation)

Qué haríamos y cómo: Utilizaremos **Burp Suite (Repeater)** para ejecutar pruebas de concepto (PoC) controladas y reproducibles. Autenticados con la sesión del *Usuario A*, solicitaremos el detalle de su pedido (`ID 101`) y capturaremos la petición. Sustituiremos dicho valor por el identificador correspondiente a una compra del *Usuario B* (`ID 102`) y enviaremos la solicitud al servidor. Asimismo, desde la cuenta de cliente regular intentaremos enviar peticiones a los endpoints del panel de empleados identificados previamente.

Por qué y qué esperamos: Esta fase valida empíricamente si la vulnerabilidad es real o un falso positivo. Si el servidor retorna el pedido del Usuario B al Usuario A, queda técnicamente probada la existencia de una falla crítica de **IDOR (Insecure Direct Object Reference)**. Si se accede al panel de empleados, se confirma un **escalamiento de privilegios vertical**.

Fase 4: Post-Explotación (Pivoting & Impact Assessment)

Qué haríamos y cómo: Una vez comprobada la brecha, no modificaremos ni eliminaremos registros de producción. Nos enfocaremos en medir la severidad e impacto potencial para el negocio: ¿La falla permite únicamente visualizar el pedido o también modificar la dirección de envío y el estado de la compra? ¿Se exponen datos de tarjetas bancarias, tokens o hashes de contraseñas? ¿Es posible mediante un script automatizado iterar todos los pedidos de la base de datos de 1 a 10.000?

Por qué y qué esperamos: Permite cuantificar el riesgo real bajo el estándar CVSS (Common Vulnerability Scoring System). La dirección de Aurora Market no solo necesita saber que existe una falla técnica, sino comprender el daño financiero, legal y de continuidad de operaciones que representaría si un actor malicioso extrajera toda la base de clientes.

Fase 5: Elaboración del Informe y Plan de Remediación (Reporting)

Qué haríamos y cómo: Redactaremos un informe final estructurado en dos secciones complementarias:

- **Resumen Ejecutivo:** Diseñado para gerencia y tomadores de decisiones, redactado en lenguaje de negocios claro y libre de jerga técnica compleja. Explica el nivel de exposición de Aurora Market, riesgos normativos por fuga de datos y el impacto económico potencial.
- **Memoria Técnica y Guía de Remediación:** Dirigida a los desarrolladores y administradores de sistemas. Contiene la descripción exacta de los hallazgos, capturas de tráfico con evidencias de la falla, criticidad CVSS y las instrucciones técnicas específicas para solucionar el problema (ejemplo: implementar validaciones en backend donde el identificador de usuario se obtenga exclusivamente del token de sesión verificado y nunca de un parámetro enviado por el cliente, además de migrar de IDs secuenciales a identificadores UUID v4).

Por qué y qué esperamos: El valor de una prueba de penetración reside en la solución. El informe asegura que el equipo de desarrollo comprenda con exactitud cómo replicar y corregir cada vulnerabilidad identificada, garantizando un entorno seguro y confiable para las operaciones futuras de Aurora Market.